

ClaraBook

Authenticated E2E Beta Readiness Audit

Production signup, legal, payment, onboarding, accounting, permissions, close, reports, runtime and recovery

VERDICT: NO-GO FOR PUBLIC BETA

Audit date: 2026-09-04 (MYT)

Fixture: Clara E2E Audit 2026-09-04 / Pine & Co E2E Sdn Bhd

Repository main: ba8e7d35cda32a288a61cbf18ab4e13cd124bcb4

Runtime measured: Fly machine version 74

审计日期：2026-09-04 (Asia/Kuala_Lumpur) 审计对象：<https://app.clarabook.com/>、生产 Web、生产 runtime、生产数据库治理门、当前 main 测试人员模型：Firm owner + Bookkeeper + 实务 accountant 测试 fixture：Clara E2E Audit 2026-09-04 / Pine & Co E2E Sdn Bhd (专用、可重置，不是 BELCORT operator firm) 代码基线：main = ba8e7d35cda32a288a61cbf18ab4e13cd124bcb4 运行环境实测：Web production；Fly clara-runtime 当前 machine version 74；数据库 production 审计方式：真实邮箱、真实 OTP、真实 sandbox checkout、真实 UI、受控测试数据；只在专用 fixture 内做可逆验证 发布结论：NO-GO - 不应直接作为 public beta 放行

1. Executive verdict

ClaraBook 已经不是“只有页面的 demo”。本次成功跑通了：新 firm 注册、邮箱 OTP、sandbox checkout、客户 onboarding、opening balance、客户激活、银行账户建立、手工 journal 草稿/批准/反转、Bookkeeper 邮件邀请/接受/登录，以及邀请链接防重放。

但这份 release candidate 仍不能称为“会计师可以独立使用的 beta”。最大风险不是颜色或动画，而是治理门、数据库真相和产品 UI 没有接成一条可恢复的用户路径。真实 accountant 会在 Opening、Consent、Bank statement、Close、Reports、Sales 等关键位置被迫找工程师或直接进数据库。

Go / No-go scorecard

能力域	结论	说明
Signup / login / email	PARTIAL	OTP 邮件到达并可验证；确认提示没有可点击路径，OTP resend 是 dead end
Legal / payment	FAIL	DPA 是 placeholder；Beta Terms 完全没有独立接受证据；runtime 不强制 Stripe test mode
Firm / Members	PARTIAL	邀请邮件、接受、密码设置、防重放都通过；角色 UI 泄露 owner-only 操作
Client onboarding	PARTIAL	7/7 + commit + active 成功；结构化答案显示 [object Object]，SSM/TIN/bank 不自动进入权威表
Opening balances	FAIL FOR NORMAL USER	数据正确后仍因 production function ceremony 缺失而 UI 无法批准，且页面静默关闭；本次只能在专用 fixture 内用受控 DB ceremony 完成
Journals	PARTIAL	Balanced draft、approve、reverse 可用；Bookkeeper 可以自己建、自己批，低于 threshold 没有职责分离
Bank	PARTIAL / BLOCKED	激活后账户可创建；statement upload/classify/extract/reconcile 未形成完整 UI 闭环
Sales / purchases	FAIL	sales lane 只能 DB 开关；CLR23 无可操作恢复；autopost runtime 仍持续调用已删除函数
Close	FAIL	FY 和 gates 可读；finalize 被真实 gate 拒绝后恢复路径差，Clara 报错“需要 active bookkeeper”
Reports	FAIL	月 snapshot 可建；报告模板与版本均为 0，没有可发布 statutory/management artifact 闭环
Tax	NOT BETA FEATURE	页面直接暴露 not-built / roadmap 内部信息
Activity / audit visibility	FAIL	完成大量真实动作后 Activity 仍为空，用户看不到操作历史
Responsive / accessibility	FAIL ON AUTH SHELL	双固定 rail 把主内容压成极窄竖列；真实 1440 desktop 尚可，窄窗/高 zoom 不可用
Release observability	FAIL	live runtime 已到 v74，但仍运行 retired autopost caller；部署版本与源码修复无法唯一绑定

Severity summary

等级	数量	发布含义
P0	4	法律、支付模式或核心会计批准链的硬阻断；未修不得放 beta
P1	15	真实 accountant 会卡死、需要工程师/DB、权限或审计语义不合格
P2	11	会造成严重困惑、重复输入、恢复困难或可访问性下降
P3	6	一致性、文案、发现性和工程治理欠缺

最短安全路径：先修 P0；同一 release 内部署 runtime retired-call fix、补 consent/identifier/opening 的产品 surface、发布至少一个 governed management-report template；然后用 clean fixture 重跑本文的 Beta Exit Pack。不要用“source 已 merge”代替“生产已运行”。

2. 审计范围、证据边界与测试数据

本次真实执行

- 新账号注册 -> OTP 邮件确认 -> firm setup -> /pending -> DPA -> Stripe sandbox MYR 0.00 -> firm home。
- Owner 的 Home、Admin、Members、Compliance、Vendor bindings、Firm settings、Activity、Needs you、Clients。
- Clara 建 client、完成 7/7 onboarding interview、opening seed、opening items、trial-balance tie、commit、client active。
- 手工建立 canonical SSM/TIN、bank account；测试 sales-lane governed switch 并恢复为 disabled。
- Journal balanced draft -> approve -> reverse；Bookkeeper maker/approver 权限测试并反转恢复净额。
- Documents、Bank、Close、Tax、Reports、Registers、Knowledge 的真实 empty/loading/error/success 状态。
- Bookkeeper invitation 邮件 -> 一次性 link -> password -> first login -> client workspace -> owner-only door refusal -> invite replay refusal。
- 生产数据库函数签名/proconfig、report template counts、consent state、canonical identifiers、member roles。
- 生产 clara-runtime status、release version、live logs；当前约每 2 秒打印一次 retired-function error。

明确没有宣称通过

- 文件上传、真实 Maybank/Alliance statement ingestion：未执行。用户选定浏览器的原生文件 chooser 被桌面安全边界拦下；直接调用 Playwright 需要另行明确授权。本项是 BLOCKED，不是 PASS。
- Typed consent grant + activate：未伪造。typed consent 必须引用 verified consent_evidence document。没有合法上传证据时，本次没有绕过治理门。
- Statutory report：未执行。生产 report_templates=0、report_template_versions=0，没有可选权威模板。
- Autopost：未执行。当前 runtime v74 仍调用已被 DB 删除的 reconcile_autopost_rules()。
- 跨 firm 数据隔离攻击包：未对真实其他 firm 发起。只验证了当前 member/owner door 和 client membership；需要 release-gate fixture 做系统化 cross-tenant ID suite。

受控、可逆的生产 fixture 动作

动作	原因	最终状态
将本 fixture 的 registration rate-wall event 后移 25h	首次 checkout 被 same-location CLR09 卡住	仅测试 fixture ；已记录
DB ceremony 批准 opening seed	生产 approve_opening_seed 缺少 serializable proconfig , UI 永远无法完成	Opening finalized ；客户后续可激活
添加 SSM/TIN canonical identifiers	验证 interview 不自动 promotion、DB 门可用	保留为该测试 client 的正确 fixture 数据
sales lane ON -> OFF	验证 governed switch ；不运行 sales posting	最终 OFF ；watermark 有审计记录
两组 journal + reversal	验证 owner 与 Bookkeeper 分录链	原 journal 均有反向分录，净额恢复

3. 完整 E2E 阶段与健康度

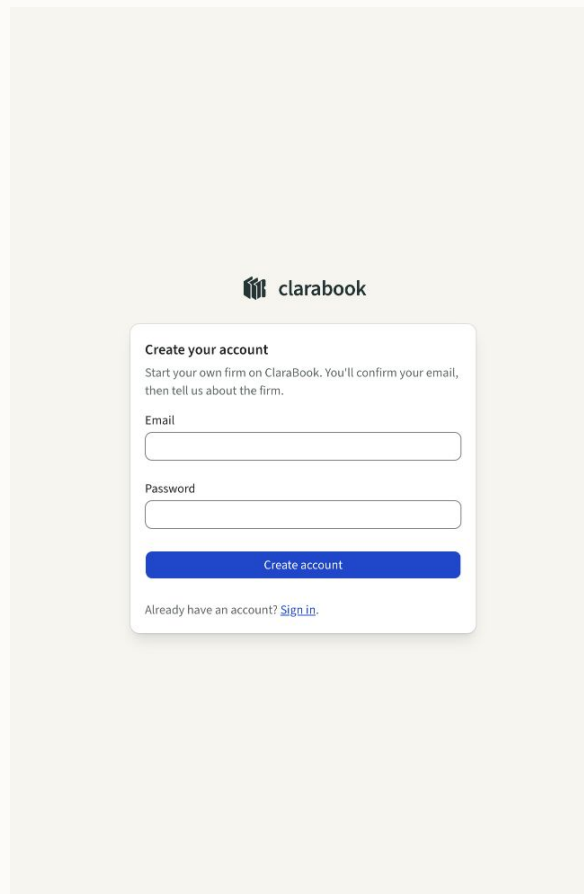
#	阶段 / 用户目标	实测结果	Health
1	打开 signup	页面清晰、字段可用	PASS
2	填账号及密码	基本验证可用；密码规则提示不足	PARTIAL
3	收 confirmation 邮件	邮件到达	PASS
4	从页面进入 OTP	提示只说 check email，没有明确 OTP route/CTA；本次手动进 /auth/confirm	FAIL UX
5	输入 OTP	713518 成功，3600 秒有效	PASS
6	Firm setup	Firm name/基本资料可填；不是完整、可恢复 firm interview	PARTIAL
7	Pending 页面	文案说"nothing more to do"，同时仍有下一步 CTA	FAIL COPY
8	DPA	可签；内容是 placeholder；Terms 不存在	P0 FAIL
9	Checkout gate	首次 CLR09 same-location rate wall；fixture 介入后可继续	PARTIAL
10	Stripe checkout	明确 sandbox，MYR 0.00，返回成功	PASS WITH P0 CONFIG RISK
11	Firm home	成功进入；出现 firm-altitude 等内部语言	PARTIAL
12	Members roster	Owner 可看/邀请；标题重复，日期/时区不一致	PARTIAL
13	Compliance / vendor bindings	正确 empty state；没有 setup CTA	PARTIAL
14	Settings	数据门生效；页面直接暴露函数和 migration 内部名	PARTIAL
15	Activity / Needs you	做完关键动作仍基本为空或显示内部 marker	FAIL
16	Clients empty state	没有 Add Client；只能从 Clara 右 rail 开始	FAIL DISCOVERABILITY
17	Clara client onboarding	成功建立客户和 interview	PASS
18	7/7 interview	SST signal timeout；最终完成	PARTIAL
19	Review answers	interview_run 和 SSM 显示 [object Object]	FAIL UI
20	Commit onboarding	被 opening position 阻断；错误本身合理，但 recovery 路径不清楚	PARTIAL
21	Opening seed + COA	可建立 1000/3000/3100/5000；可 draft	PASS
22	Opening "Ties"	OBE=0 时 UI 显示 ties，但没有 TB target 时 approval 仍 tie_mismatch	FAIL SEMANTICS
23	Opening approval	Browser 两次提交都静默关 dialog；DB function 缺 serializable ceremony	P0 FAIL
24	Controlled opening finalize	加入 TB targets 后，serializable DB ceremony 成功	PASS AT DB / FAIL PRODUCT

#	阶段 / 用户目标	实测结果	Health
25	Commit client active	7/7 committed , client active	PASS
26	Interview facts rehydrate	Clients 仍显示 entity/MSIC 空 , Bank/Identifiers 不自动生成	FAIL
27	Add bank account	Active 后 MBB + account + GL link 成功	PASS
28	Bank statement form	有 account selector/date/period/balance/lines ; 文件上传链未获完整执行	BLOCKED
29	Bank matching / exceptions / recon	多处 empty、duplicate、not-built , 尚无完整 statement 作为输入	FAIL/BLOCKED
30	Owner journal	RM10 balanced draft、approve、reverse 成功	PASS
31	Journal semantics	tab 叫 Posted , row 状态叫 Approved ; 同一 draft 有 Approve 与 Approve (routine)	FAIL UX
32	Bookkeeper invitation mail	邮件清晰 , 角色、expiry、一次性特性明确	PASS
33	Accept invitation	Password setup、首次登录、firm home 成功	PASS
34	Invite replay	已使用 link 被明确拒绝	PASS
35	Bookkeeper client access	Clients 和 client journal 可用	PASS
36	Bookkeeper owner-only Admin	控件可见 ; DB 拒绝 threshold change (CLR04)	SECURITY WALL PASS / UX FAIL
37	Bookkeeper Members	Email 正确 mask ; Invite disabled ; 但 role/action menu 可展开并显示 owner controls	PARTIAL
38	Bookkeeper maker-checker	自建 RM1 draft 后可自己 Approve , 立即进入 Posted	P1 FAIL
39	Close	FY2026 和 gates 可读 ; 真实 gate 拒绝 finalize	PARTIAL
40	Clara close-prep	Owner 有 active client/owner session , Clara 仍说需要 active bookkeeper	FAIL
41	Reports	Monthly snapshot 可创建 ; recipient 显示 raw UUID ; 无 template/artifact	FAIL
42	Tax	not-built/roadmap 信息直接面对 beta 用户	FAIL
43	Registers	Opening 可完成 ; fixed assets tie 在空数据下给 vacuous pass	PARTIAL
44	Knowledge	Onboarding 后仍为空 , SSM/TIN/MSIC 没有可见 promotion	FAIL
45	Runtime/autopost	v74、health 2/2 , 但 logs 每约 2 秒 missing-function error	P1 FAIL
46	Responsive shell	窄窗口/高 zoom 下两个 rail 将 Close 主内容压成单字竖列	P1 FAIL

4. 截图证据与 remarks

以下为本次真实 production run 的代表证据。完整截图目录见附录 A , 共 79 张。

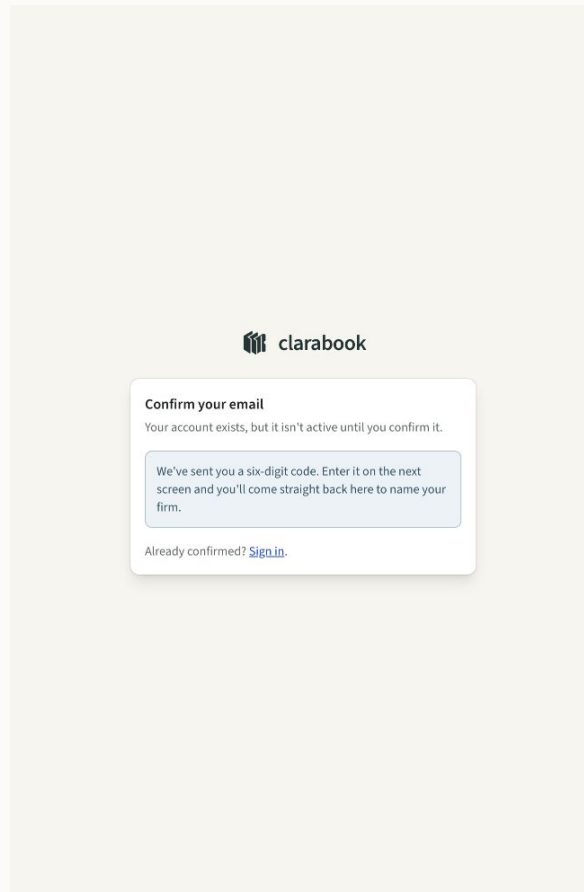
Figure 1 - Signup 起点

The image shows a web page for creating a new account on ClaraBook. At the top center is the ClaraBook logo, which consists of a stylized 'C' icon followed by the text 'clarabook'. Below the logo is a white rectangular form with a subtle shadow. Inside the form, the heading 'Create your account' is followed by a paragraph: 'Start your own firm on ClaraBook. You'll confirm your email, then tell us about the firm.' There are two input fields: 'Email' and 'Password', each with a light gray border. Below the 'Password' field is a blue button with the text 'Create account' in white. At the bottom of the form, there is a link that says 'Already have an account? [Sign in](#)'.

Evidence: Signup start

Remark : 视觉干净、信息层级好；但密码政策没有在输入前说明，后续 invite/reset 也必须使用同一政策来源。

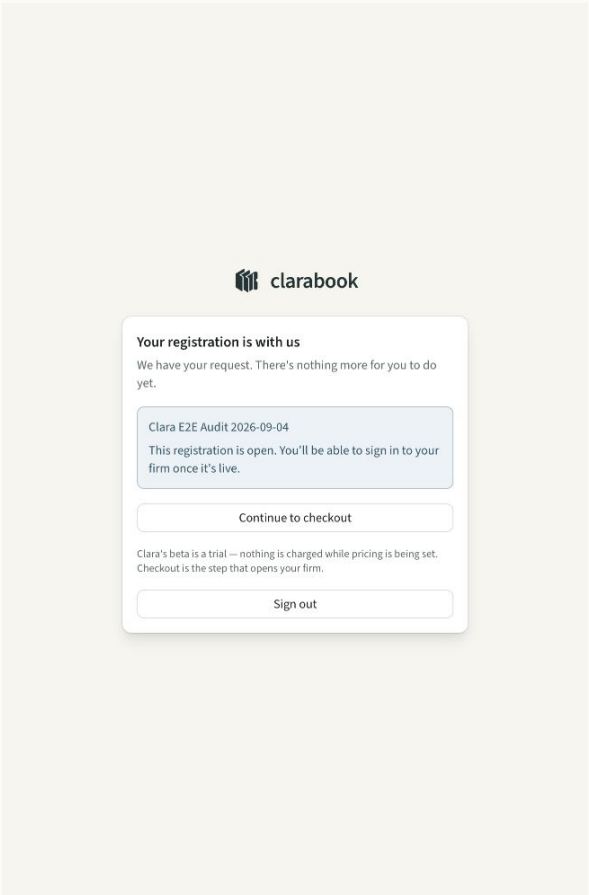
Figure 2 - Confirmation notice 没有 OTP 路径



Evidence: Confirmation notice

Remark：用户只知道“去看邮箱”，没有明确“输入六位 OTP”的按钮或 deep link。真实用户如果邮件 template 只有 code，会停在这里。

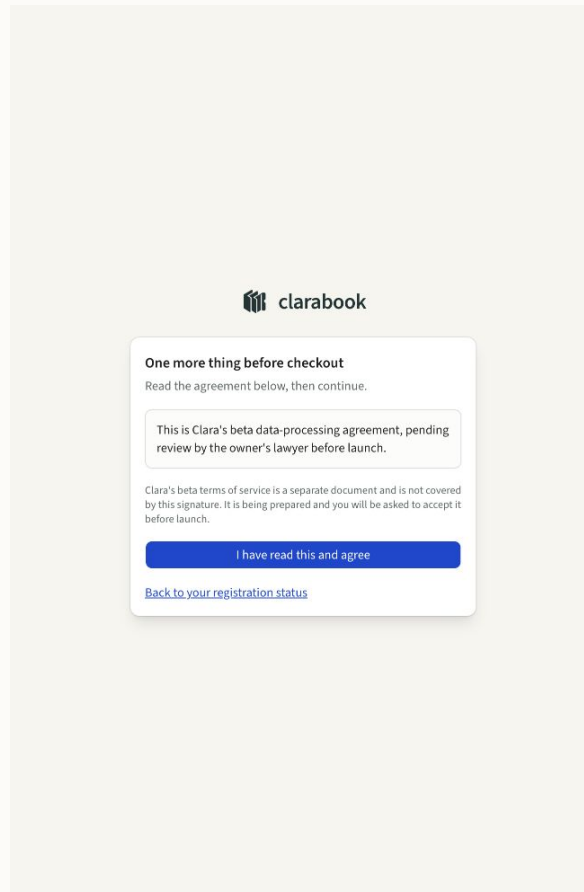
Figure 3 - Pending 文案互相矛盾



Evidence: Registration pending

Remark：页面同时表达“无需再做什么”和“仍需继续”，破坏流程信心。

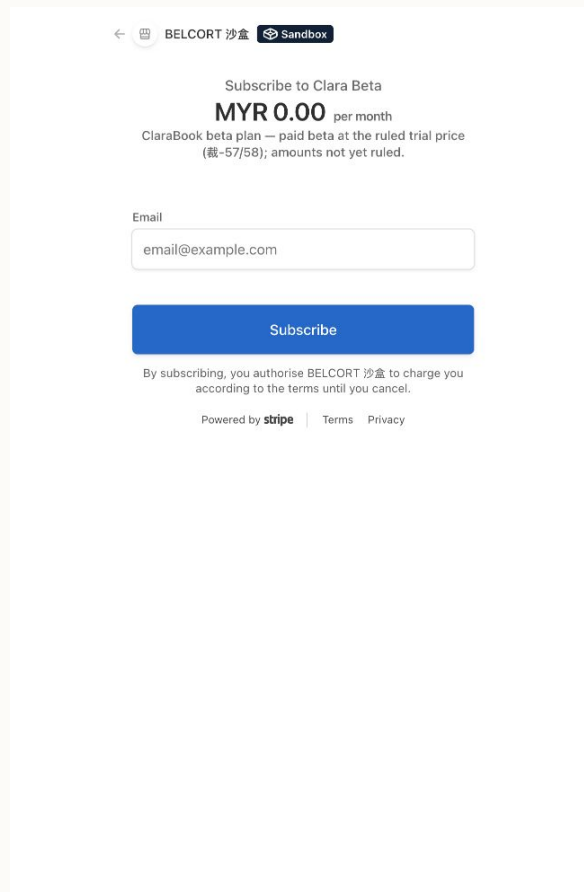
Figure 4 - DPA gate



Evidence: DPA gate

Remark : Beta Terms 没有独立 checkbox/receipt ; DPA 文本仍为 placeholder。法律接受证据不是 polish , 而是 checkout 前的 P0 gate。

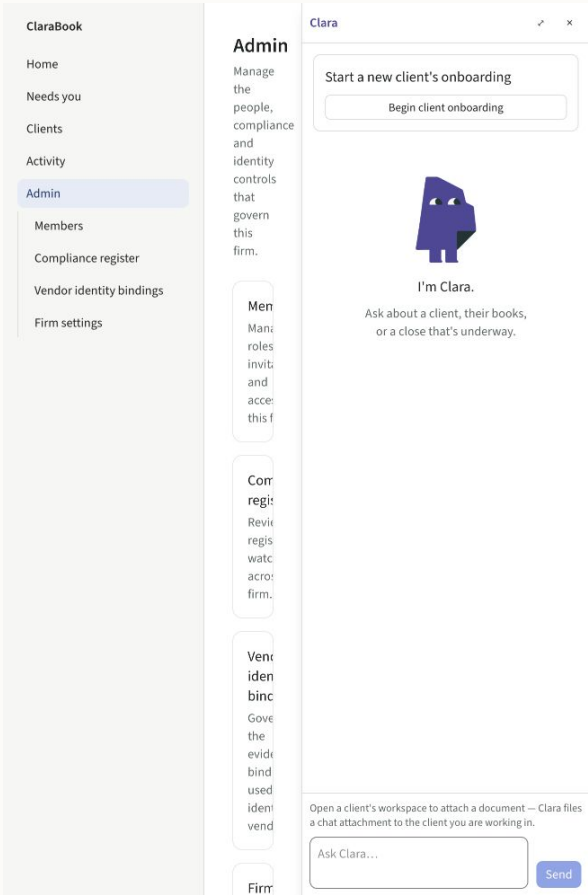
Figure 5 - Stripe sandbox



Evidence: Stripe sandbox

Remark : 本次 checkout 确实是 sandbox、MYR 0.00 ; 风险在 runtime 没有拒绝 live key , 错误环境变量仍可能把 beta 指向 live Stripe。

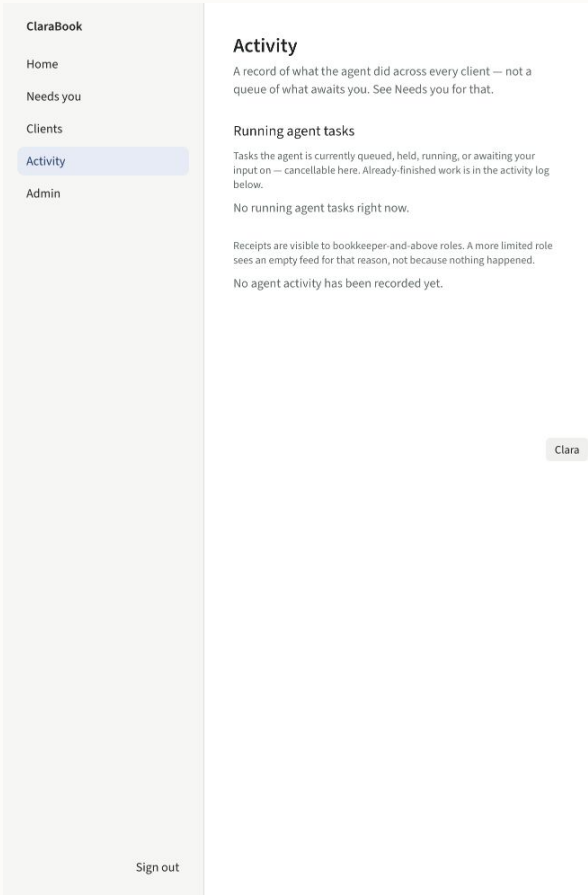
Figure 6 - Admin 导航和内部产品语言



Evidence: Admin rail

Remark : Admin 下把大量后台治理暴露给普通成员；后续 Bookkeeper 也能看到相同入口。

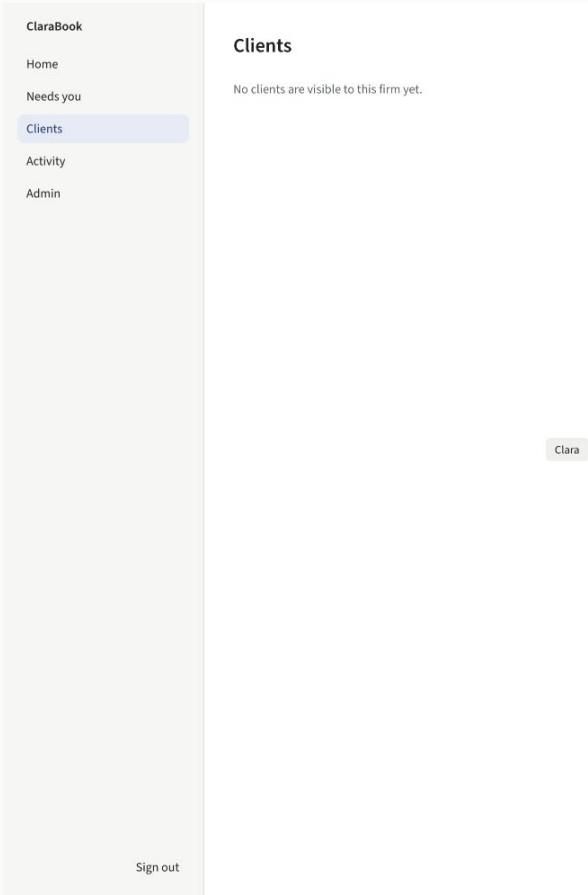
Figure 7 - Activity 在真实动作后仍为空



Evidence: Activity empty

Remark：注册、签 DPA、checkout、建客户、批准 journal 后，用户仍无法在产品内追溯“谁做了什么”。

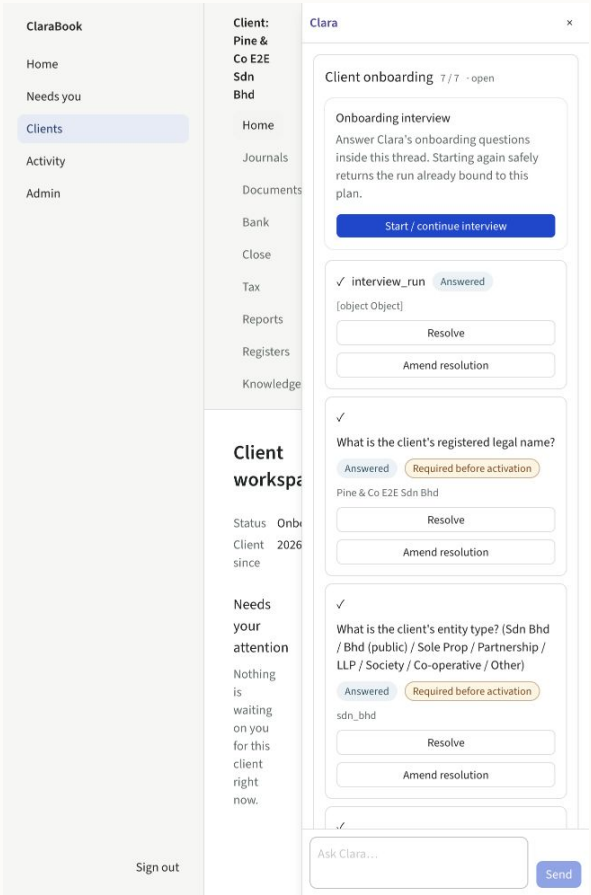
Figure 8 - Client list 没有主 CTA



Evidence: Clients no CTA

Remark：新 accountant 的自然目标是“Add client”，但唯一入口藏在 Clara rail。

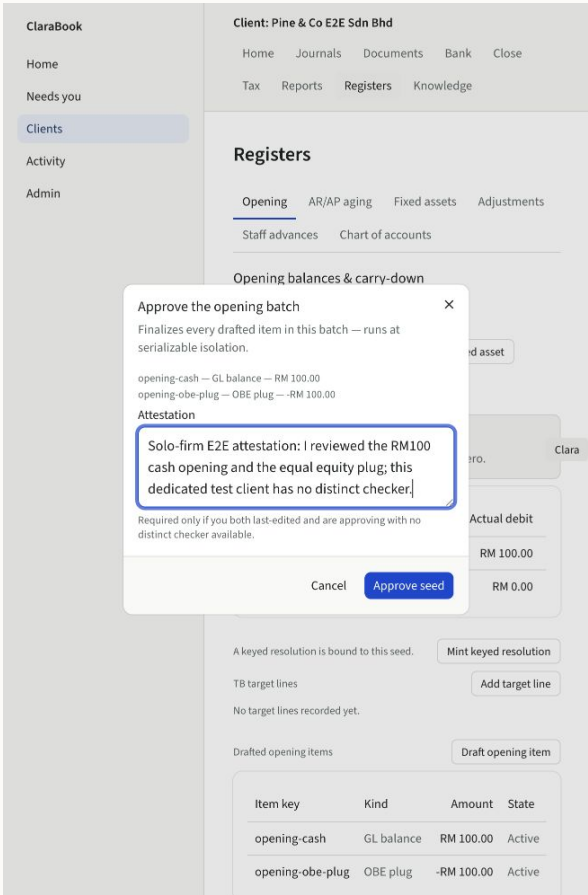
Figure 9 - Interview 完成却渲染 [object Object]



Evidence: Interview object object

Remark：这是结构化数据直接进入文本 UI 的典型 frontend boundary bug；同时让用户无法确认 SSM 是否正确。

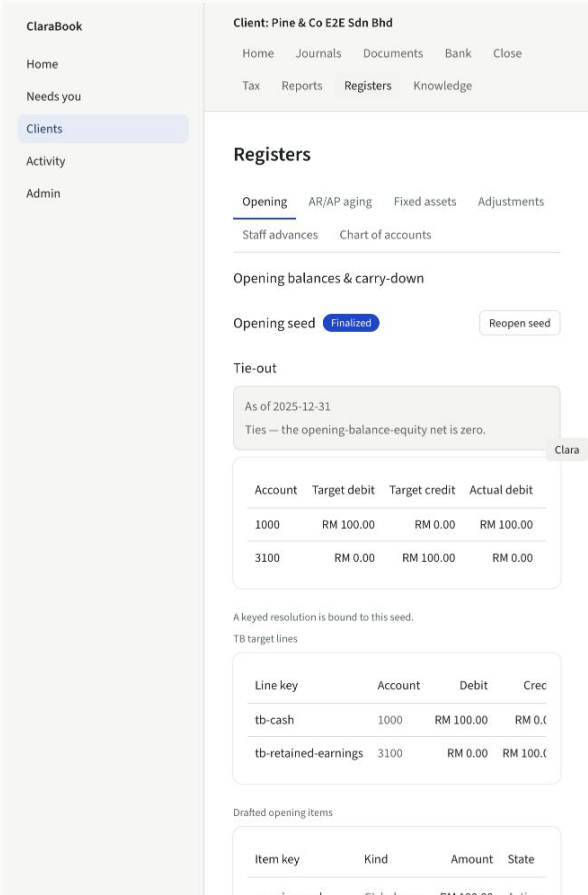
Figure 10 - Opening approval attestation



Evidence: Opening approval attestation

Remark : Attestation 的设计方向对，但生产 function 缺少 serializable proconfig，点击后 dialog 静默关闭而不告诉用户失败。

Figure 11 - Opening finally finalized



Evidence: Opening finalized

Remark：加入完整 TB targets 并从受控 serializable DB ceremony 批准后才成功。这证明核心 DB 模型可工作，也证明正常 UI 路径仍断裂。

Figure 12 - Client active 后双 rail 仍挤压主区

ClaraBook

Home

Needs you

Clients

Activity

Admin

Sign out

Client: Pine & Co E2E Sdn Bhd

Home

Journals

Documents

Bank

Close

Tax

Reports

Registers

Knowledge

Client workspace

Status Active

Client 2026 since 09-04

Needs your attention

Nothing is waiting on you for this client right now.

Client onboarding 7 / 7 - committed

Onboarding interview

Answer Clara's onboarding questions inside this thread. Starting again safely returns the run already bound to this plan.

Start / continue interview

This onboarding plan was committed on 4 Sept 2026, 6:43 am. The client is active.

✓ interview_run Resolved

[object Object]

Resolve

✓

What is the client's registered legal name?

Answered Required before activation

Pine & Co E2E Sdn Bhd

Resolve

✓

What is the client's entity type? (Sdn Bhd / Bhd (public) / Sole Prop / Partnership / LLP / Society / Co-operative / Other)

Answered Required before activation

sdn_bhd

Resolve

✓

What is the client's SSM registration

Ask Clara...

Send

Evidence: Client active

Remark : committed/active 状态清楚 ; 但 Commit/Cancel 仍显示 , rail 占宽让主任务区非常窄。

Figure 13 - Bank account 建立成功

ClaraBook

Home

Needs you

Clients

Activity

Admin

Sign out

Client: Pine & Co E2E Sdn Bhd

Home

Journals

Documents

Bank

Close

Tax

Reports

Registers

Knowledge

Bank

Accounts

Statements

Matching

Exceptions

Reconciliation

Agent

Open account proposals

A statement was uploaded for a bank identity this client doesn't have on file yet.

Nothing here yet.

Add a bank account

Bank code

Account number

Display name

Chart-of-accounts code

Add account

Bank accounts

Pine Operating Account - 514022000001

Bound to chart account 1000

Deactivate

Evidence: Bank account created

Remark : Active client + canonical account + GL link 路径通过。Onboarding 中已经回答的 bank facts 没有自动进入这里，造成重复输入。

Figure 14 - Owner journal balanced draft

ClaraBook

Home

Needs you

Clients

Activity

Admin

Client: Pine & Co E2E Sdn Bhd

Home

Journals

Documents

Bank

Close

Tax

Reports

Registers

Knowledge

Journals

New journal entry

Drafts & review queue

Posted

Clarifications (0)

New journal entry

A manual entry — recorded via record_client_resolution + draft_entry, the DB's own manual-compose ceremony.

Posting date

04/09/2026

Memo

E2E manual journal — office expense paid from bank

Account	Description	Debit	Credit
5000 — Office expe	Office expense	10.00	0.00
1000 — Cash at bai	Bank payment	0.00	10.00
Totals (presentation sum)		RM 10.00	RM 10.00

Add line

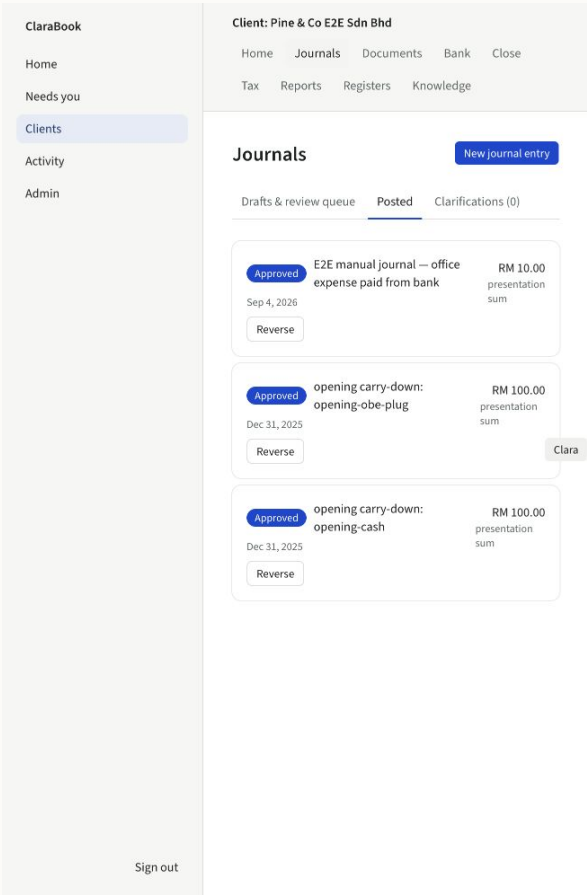
Create draft

Sign out

Evidence: Journal balanced draft

Remark：借贷平衡和 totals 表现清楚；dialog 却直接暴露 record_client_resolution + draft_entry 内部函数名。

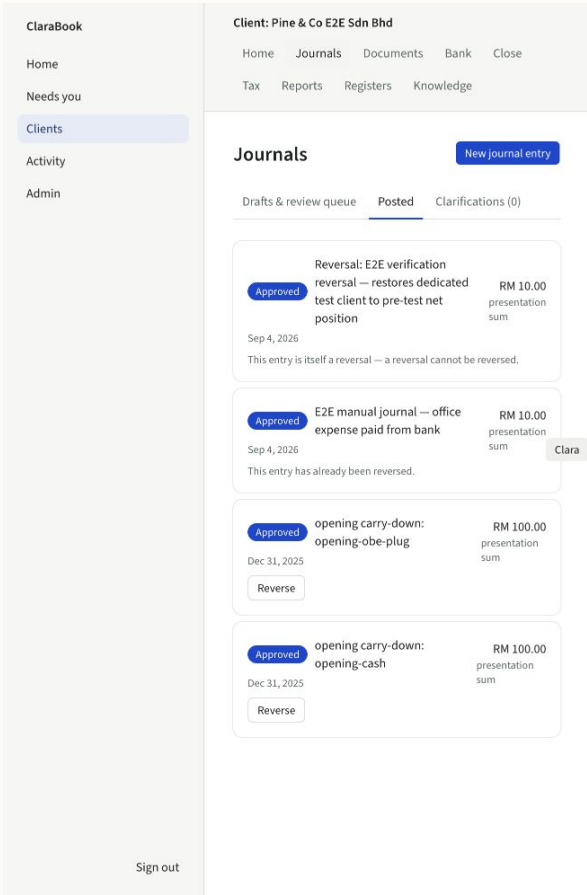
Figure 15 - Approved 出现在 Posted tab



Evidence: Journal approved

Remark : Approved、Posted、Approve (routine) 没有解释其会计含义；用户无法判断批准是否等于过账。

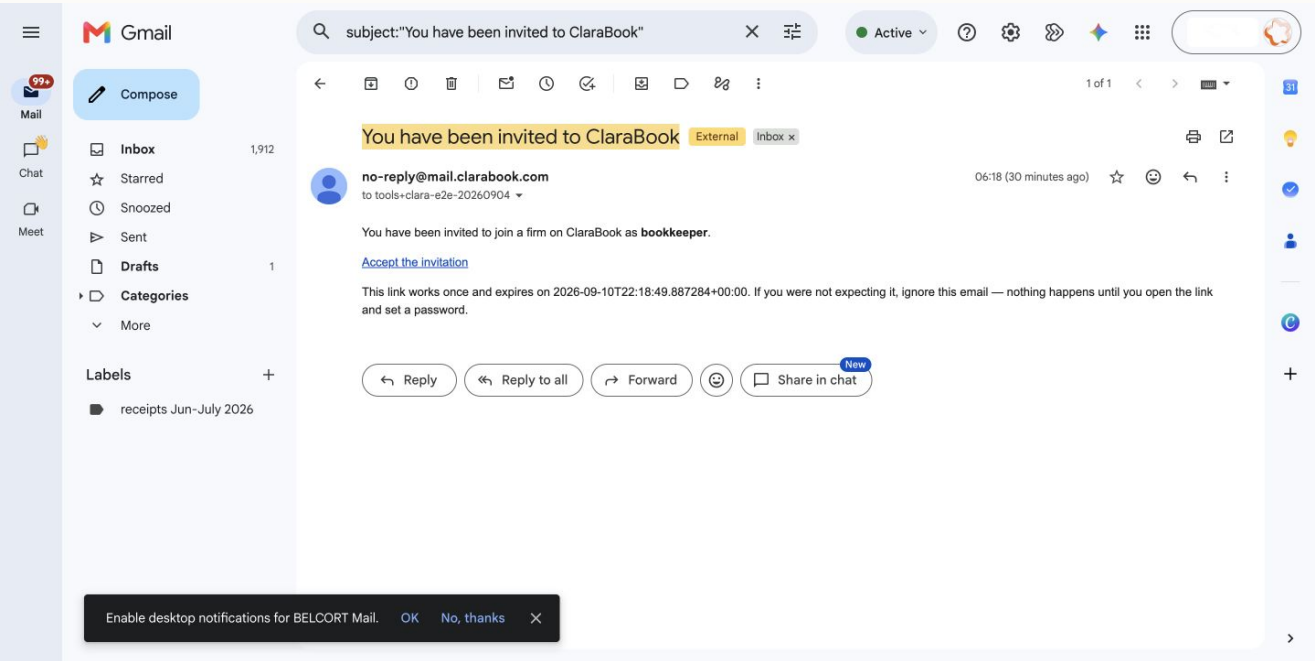
Figure 16 - Reversal 闭环



Evidence: Journal reversal

Remark：需要 reason、生成反向分录、原分录标记 already reversed，核心审计语义正确。

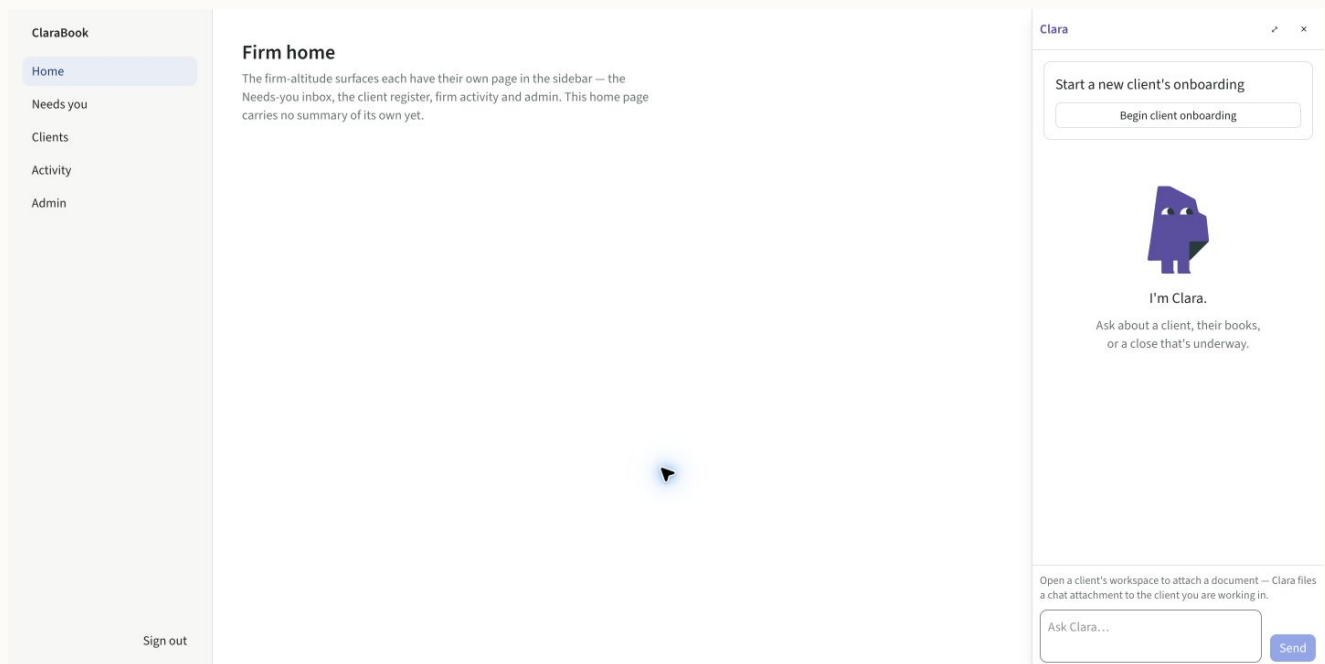
Figure 17 - Bookkeeper 邀请邮件



Evidence: Invitation email

Remark : 邮件说明 role、一次性和 expiry , 是本次表现最成熟的路径之一。

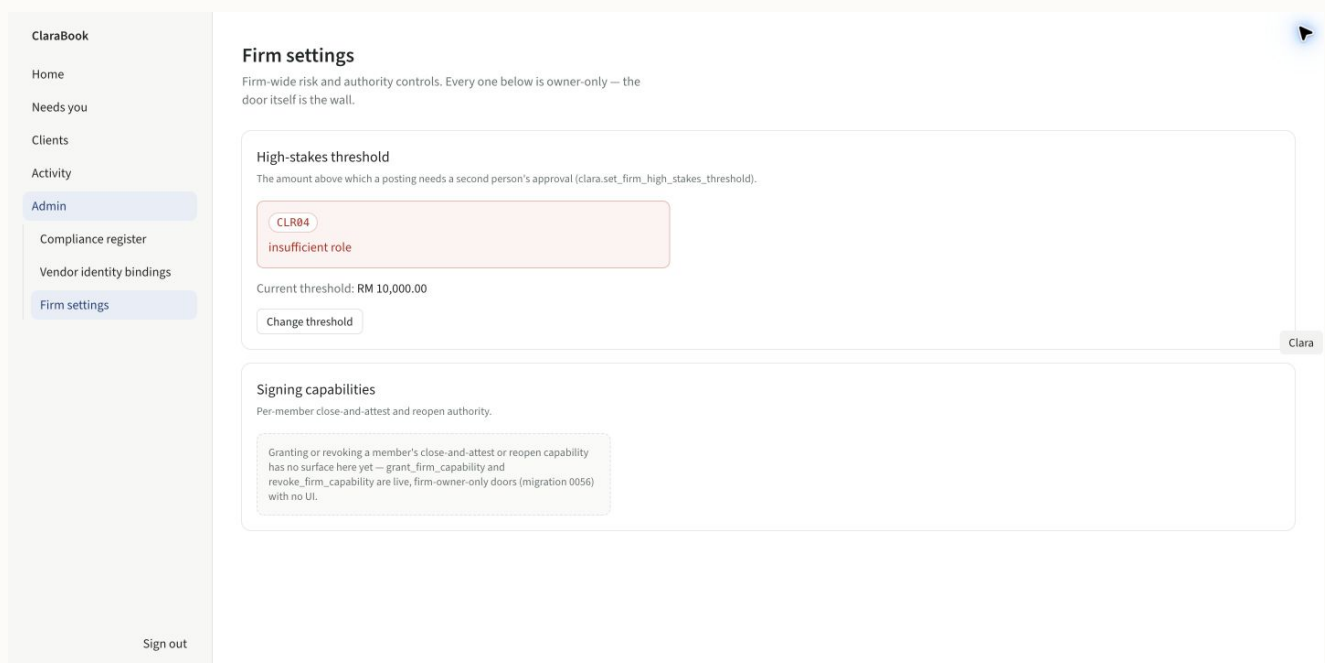
Figure 18 - Bookkeeper first login



Evidence: Bookkeeper first login

Remark : 密码设置后顺利进入 firm ; 截图没有保留任何密码。

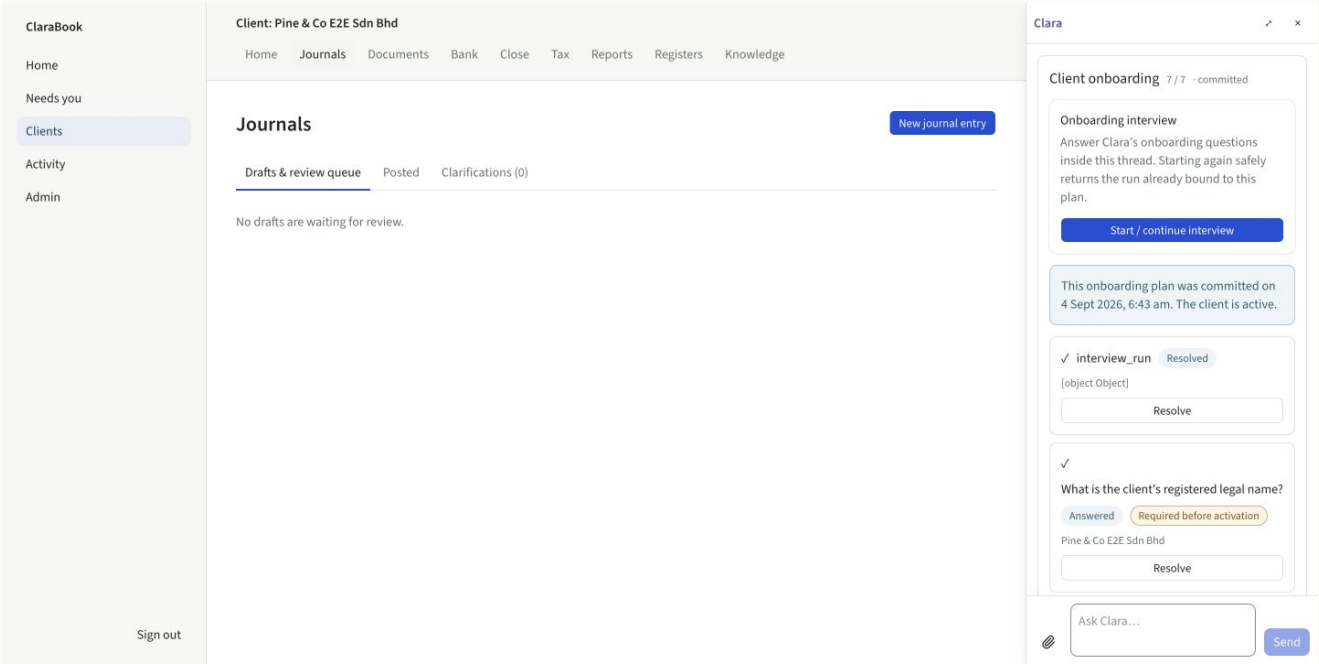
Figure 19 - DB 拒绝 Owner-only 操作，但 UI 仍暴露它



Evidence: Bookkeeper owner door refused

Remark : CLR04 insufficient role 证明数据库是最后一道墙 ; Bookkeeper 本不应看到可点的 Change threshold。

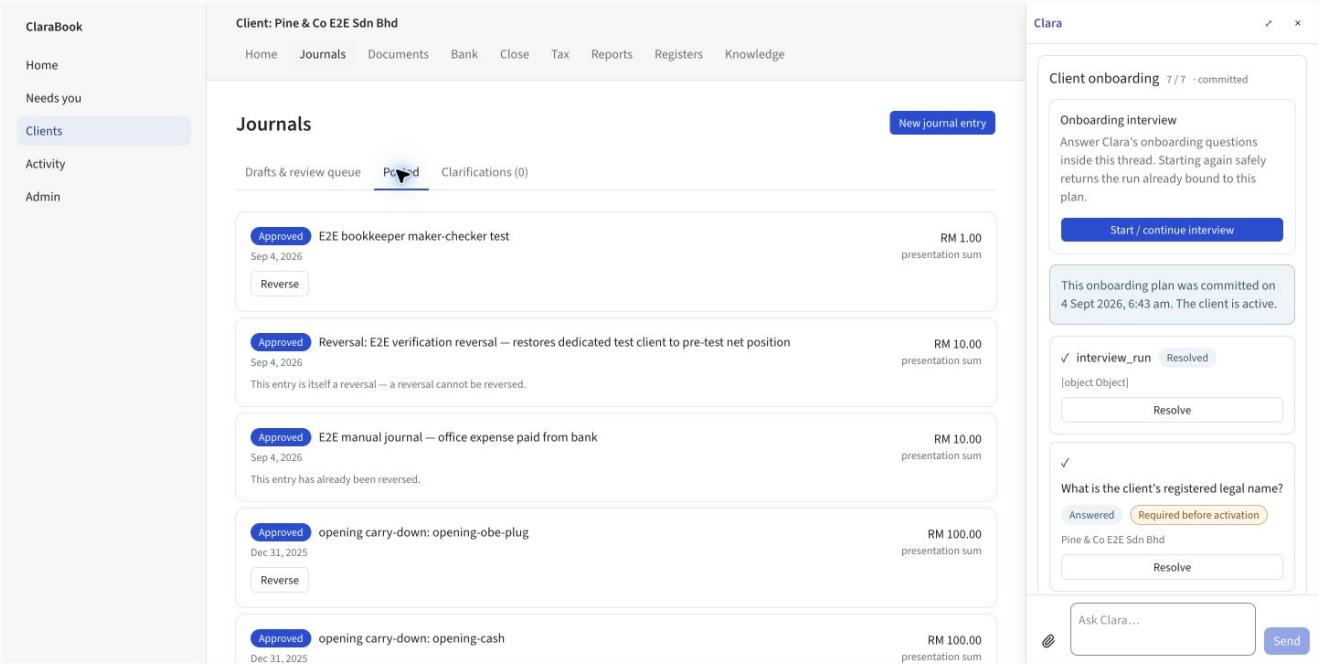
Figure 20 - Bookkeeper 可进入 client journal



Evidence: Bookkeeper client journal

Remark：正常工作区权限通过；右 rail 仍显示 onboarding Commit/Cancel 和 [object Object]。

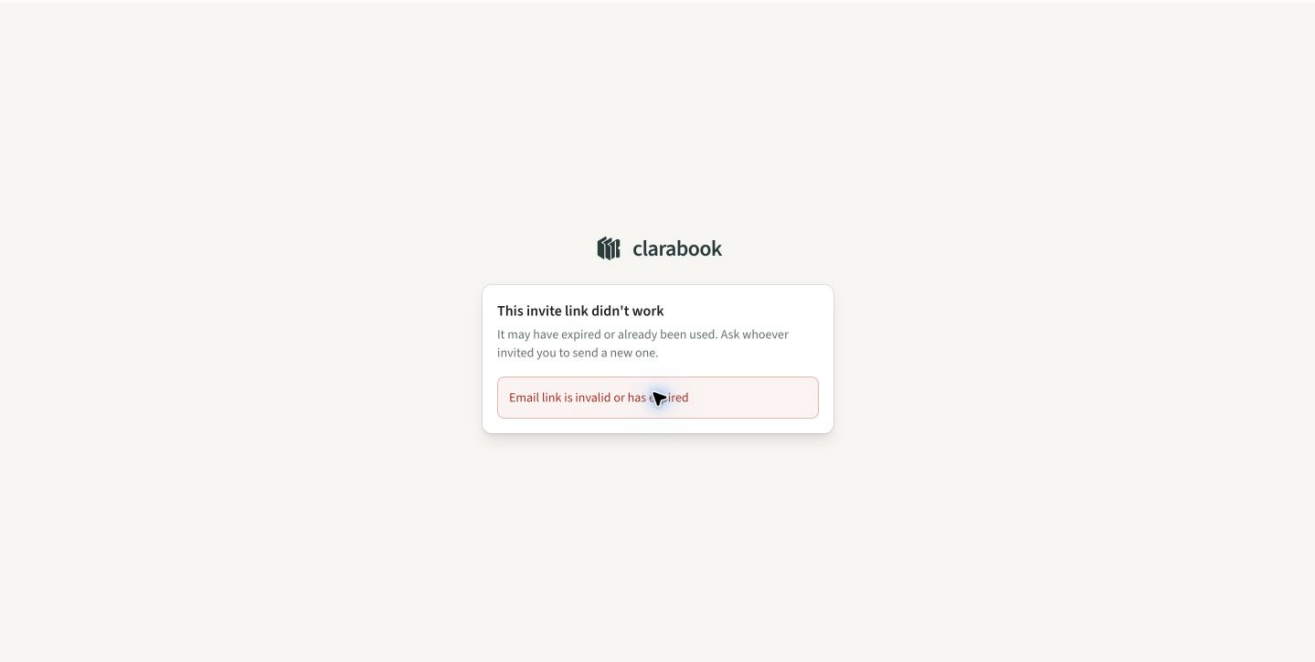
Figure 21 - Bookkeeper 自建自批 RM1 journal



Evidence: Bookkeeper self approved

Remark：同一 Bookkeeper 是 maker 和 approver，记录立即进入 Posted。若这是 threshold-based policy，产品必须明确显示；若 beta 承诺 maker-checker，则这是 P1 权限/审计缺陷。

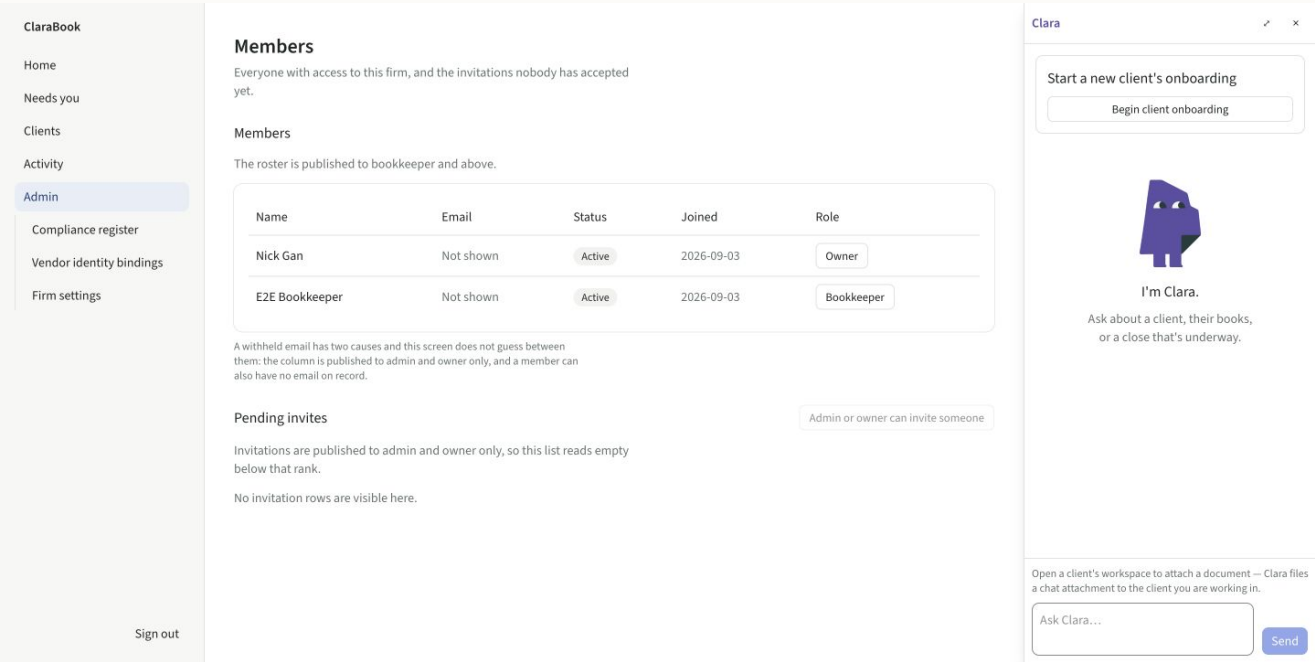
Figure 22 - 邀请链接防重放



Evidence: Invite replay refused

Remark：已使用 link 被正确拒绝，安全结果通过。

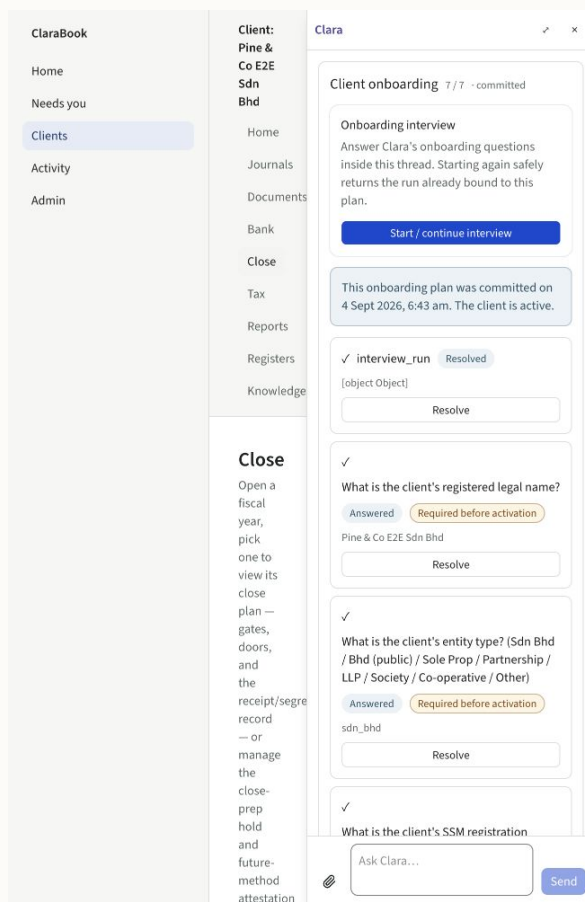
Figure 23 - Bookkeeper Members masking



Evidence: Bookkeeper members

Remark：Email masking 和 Invite disabled 正确；Actions menu 仍可展开 owner/member role controls，应在 UI capability 层直接隐藏。

Figure 24 - Authenticated shell 响应式失效



Evidence: Close squeezed by rails

Remark：在较窄窗口/高 zoom 等效状态，左 rail + client rail + Clara rail 将 Close 内容压成单字竖列。它不是“有点挤”，而是任务不可完成。

5. Defect register - 工程师可直接修

P0 - Release stop

CB-AE2E-001 - Beta Terms 没有独立接受证据

复现：Signup -> DPA -> checkout；页面只签 DPA，Terms 没有 checkbox、version、hash 或 receipt。用户影响：Firm 可进入商业关系但无法证明接受服务条款。根因证据：

[apps/web/components/entry/signup-dpa-form.tsx](#)；[docs/product/PRD.md](#)；[docs/ops/legal/clara-beta-terms.md](#)。

修复：在唯一 legal source 完成 Terms；DPA 和 Terms 各自有 version/hash/checkbox/receipt；checkout gate 校验两份 current receipt。验收：任一未勾选都不能创建 Stripe session；DB 有两份独立 receipt；旧版本 fail closed；browser E2E 证明顺序。

CB-AE2E-002 - DPA 仍是 placeholder，却已经能进入 checkout

复现：[/dpa](#) 直接查看内容并签署。影响：用户签的是未完成文本，证据有效性有法律风险。修复：法律 owner 冻结 final bytes；hash 固定；placeholder/[verify] 出现在生产时 deploy fail。验收：release pipeline 检测 placeholder/verify token；receipt hash 可反查 exact bytes。

CB-AE2E-003 - Stripe sandbox 没有 runtime hard gate

复现：本次看到 sandbox，但 source 只检查 secret 存在，不拒绝 `sk_live_*`。影响：配错环境变量即可向 live Stripe 创建对象；以后非零金额可能真实扣款。根因：[apps/web/lib/checkout/stripe-session.ts](#)。修复：startup + request 双层拒绝 live-mode key；部署 preflight 调 Stripe mode；build manifest 记录 mode（不记录 secret）。验收：live/restricted-live key 在任何 network call 前被拒；test key 正常完成 checkout/callback/claim。

CB-AE2E-004 - Opening approval 在 production UI 不可能完成且静默失败

复现：balanced items + OBE=0 + TB targets -> Approve；dialog 关闭，seed 仍 open。生产证据：[approve_opening_seed.proconfig = search_path=clara, pg_temp](#)，缺少要求的 [default_transaction_isolation=serializable](#)；[packages/db/deploy/wave-b-0017-ceremony.sql](#) 明确要求该 ceremony。Frontend 根因：action catch 后返回 false，但 dialog wrapper 无视 boolean 并关闭。影响：每一个新 client 都会卡在 activation 前；只有工程师进 DB 才能放行。修复：部署正确 proconfig ceremony；UI 只有 `ok=true` 才关闭；显示 typed refusal；approval preflight 放进 release gate。验收：clean client 全程 UI finalize；失败时 dialog 保持、错误聚焦；[show_transaction_isolation/proconfig](#) 都是 serializable；无 DB bridge。

P1 - Beta blockers

CB-AE2E-005 - Runtime v74 仍每约 2 秒调用已删除 autopost function

实测：[fly status](#) machine version 74、2/2 health；live logs 连续输出 [reconcile_autopost_rules error: function ... does not exist](#)；live bundle 仍包含 literal；DB function count=0。影响：autopost 无法作为 beta 功能验证；log flood 掩盖真实事故；“v72 会修”已被当前 v74 生产事实推翻。修复：找出 v72-v74 为什么没有带入 current-main retired-caller removal；以 artifact digest 而非版本号确认；重新部署。验收：至少 10 分钟无此 log；served bundle 不含 executable call；DB function 保持删除；expired-rule tests 仍通过。

CB-AE2E-006 - OTP confirmation 缺可发现路径，resend 是 dead end

影响：普通用户拿到 code 但不知道在哪里输入；过期/未收到时只能重做 signup。修复：notice CTA -> [/auth/confirm](#)；server-side resend 共用 rate wall；generic response；新 code 使旧 code 失效。验收：新用户无需手输 URL；expired -> resend -> new OTP 成功；不泄露账号存在性。

CB-AE2E-007 - DPA signed state 在重新登录后不 hydrate

实测：已签 receipt 的注册再次进入仍要求同意；提交后又回复 already signed。修复：页面 loader 以 server receipt 为 truth；已签 current version 直接进入下一阶段。验收：refresh/relogin 不重复签；version change 才重新要求。

CB-AE2E-008 - Onboarding 结构化答案渲染 [object Object]

影响：accountant 无法审核最关键的 SSM/interview state。修复：在 response presenter 建 typed formatter；未知 object 显示安全摘要或 fail with diagnostic，禁止 JS implicit string conversion。验收：SSM 统一号/旧号各字段清晰；单元 + browser test 不允许 [object Object]。

CB-AE2E-009 - Interview facts 不 promotion 到 canonical client truth

实测：7/7 committed 后 Clients 的 entity/MSIC 仍 -；SSM/TIN/bank account 需在 DB/Bank tab 再输入。影响：重复输入、CLR23、Bank empty、Knowledge empty。修复：commit 前增加 review/confirm promotion：SSM/TIN -> [client_identifiers](#)；bank -> institution/account/account label；entity/MSIC/FYE -> canonical client facts。验收：一次输入、一次确认、立即 rehydrate；retry idempotent；冲突 abstain，不猜。

CB-AE2E-010 - Typed consent Grant + Activate 没有产品 surface

生产证据：general/typed/activation live counts 全为 0；typed grant 强制 verified consent-evidence document；activate 是第二道独立门。影响：statement extraction、witness extraction、document processing 等合法操作无法由 owner 自助开启。修复：Owner-only Consent Center：上传/验证 evidence -> Grant exact purpose -> Activate；显示 Revoke/Deactivate 与 receipt。验收：Grant alone 仍 block；Activate 只开放 exact purpose；revoke 立即 block；non-owner/cross-tenant 拒绝。

CB-AE2E-011 - Bank statement end-to-end 仍不可完成

已知并由 surface 验证：form 存在但没有完成真实 upload/classify/extract/reconcile；Maybank/Alliance 映射已知失败；Exceptions 仍 not-built。修复：将 classify、period parse、institution normalization、account binding、line parse 分成可见 stages；补真实去敏 corpus；未知时间精确问题。验收：Maybank=MBB、Alliance=ALB；period/account/balances/lines 正确；不确定 fail closed；一条 statement 全 UI 入账与 recon。

CB-AE2E-012 - Sales lane 是 DB-only 开关，CLR23 没有用户恢复

实测：set_sales_lane_activation 可在 governed door ON/OFF，本次最终 OFF；产品无 surface。影响：accountant 无法判断为什么 invoice 不处理，也不能安全 resolution/requeue。修复：owner status/activation UI + watermark explanation；CLR23 显示 scoped candidates/reason；确认后只 requeue 一次。验收：默认 OFF 清楚；ON 后只处理 watermark 后新文档；ambiguous 不猜；resolution idempotent。

CB-AE2E-013 - Bookkeeper 可自己建立并自己批准 routine journal

复现：Bookkeeper -> New journal -> Dr Office expense RM1 / Cr Cash RM1 -> Create draft -> Approve -> 立即进入 Posted。影响：如果产品承诺 maker-checker，这直接破坏职责分离；若 threshold policy 允许，也必须给 owner 明确配置和 audit disclosure。修复建议：beta 默认不同人批准所有 manual journals；或清楚定义 under-threshold self-approval policy，并在 row、receipt、settings 明示。验收：maker 点 approve 得到 typed same_actor refusal；owner/other approver 可批；solo-firm 只能走明确 attestation exception。

CB-AE2E-014 - Bookkeeper 能看到 Owner-only Admin controls

复现：Bookkeeper 访问 /admin/settings 看见 Change threshold；点击后 DB 才 CLR04。Members action menu 也显示 role/remove controls。影响：用户不断走进 dead end；也扩大内部能力枚举。修复：capability read 在 server layout 统一计算；route、nav、button、menu 同一 source 隐藏/disabled，并保留 DB wall。验收：Bookkeeper DOM/AX tree 没有 owner-only controls；直接 URL typed 403；Owner 正常可用。

CB-AE2E-015 - Close 的 Clara 权限/feature refusal 文案错误

复现：Owner + active client + committed onboarding；Clara 回答 an active bookkeeper-or-higher firm session is required，但 session 明明是 owner。根因方向：freeform allow-list/close feature state 被错误映射成 role error。修复：role、feature disabled、allow-list missing、read unavailable 四种 typed state 分开；不要共用 copy。验收：同一 owner request 返回真实 close blockers；disabled 时说 disabled；role 不足时才说 role。

CB-AE2E-016 - Close abandon 后缺清晰 restart/recovery

实测：FY open、gates 可读；finalize 被 drawer1_state_unknown 拒绝；abandon 后 Begin close 消失或状态含混。修复：run state machine 明确 not_started/in_progress/blocked/abandoned/finalized；abandoned 有 Restart；保存 blockers 和 receipt。验收：每一状态一个主 CTA；refresh 后一致；不能靠本地状态判断 readiness。

CB-AE2E-017 - Reports 没有任何模板或 artifact

生产读数：report_templates=0、report_template_versions=0、本 client report_artifacts=0。影响：fresh firm 无法完成 governed report journey。修复：通过 canonical publish door 发布至少一个 approved management template；UI 提供 select->run->seal->download。Statutory 留在 verified wording gate 后。验收：clean reset 有 current published management template；deterministic figures；immutable versions；authorized bytes。

CB-AE2E-018 - Activity 没有向用户展示真实审计事件

复现：完成 signup、DPA、checkout、client、opening、journals、invitation 后 Activity 仍 empty。影响：accountant/owner 无法追责或解释账务变化。修复：从 authoritative audit/event read model 发布用户可读 timeline；敏感 payload mask。验收：journal approve/reverse、member invite/accept、opening finalize 都有 actor/time/object/result。

CB-AE2E-019 - Authenticated shell 在窄窗/200% zoom 不可用

复现：左 firm rail + client rail + Clara rail 同时存在，Close 主内容被压成单字列。修复：breakpoint 下 firm rail drawer、client nav horizontal/overflow menu、Clara overlay/collapsed；保留 focus return。验收：1280×720 native 200% zoom 主内容至少 320 CSS px；无 page-level 横滚；键盘可开关 rail。

P2 - Must fix before broad beta

CB-AE2E-020 - Opening “Ties” 语义误导

OBE net zero 时显示 ties，但 approval 仍因缺 TB targets 失败。将 OBE cleared、TB targets present、every account ties 拆成三个明确 gate。

CB-AE2E-021 - Journal 的 Approved / Posted / routine 用词不一致

定义状态机和会计含义；同一 screen 只保留一个 primary approval action，routine 作为 policy detail，不应是重复按钮。

CB-AE2E-022 - 内部函数、migration、roadmap 文案暴露给用户

包括 record_client_resolution + draft_entry、clara_set_firm_high_stakes_threshold、migration number、firm-altitude、not-built roadmap。建立 user-copy layer；diagnostic ID 放 expandable details。

CB-AE2E-023 - Client onboarding committed 后仍显示 Commit/Cancel

Server status 是 committed 时，隐藏 mutable controls；显示 receipt 和 completed summary。

CB-AE2E-024 - Clients list 没有 Add Client 主 CTA

在 empty/non-empty list 都提供 Add client，动作可以打开 Clara flow，但入口不应只藏在 rail。

CB-AE2E-025 - Members 信息架构与日期不一致

重复 Members heading；joined date 显示前一日/UTC；同一 locale/timezone formatter 驱动 email 与 UI。

CB-AE2E-026 - Needs you 使用内部 marker/不完整 copy

把 internal code 映射为“发生了什么 / 为什么需要你 / 下一步 / 截止时间”。

CB-AE2E-027 - Reports recipient 显示 raw UUID

显示 member display name/email/role；UUID 只在 diagnostic details。

CB-AE2E-028 - Close hold 显示 raw user UUID

同上；操作人必须是人类可识别 identity。

CB-AE2E-029 - Registers 的空数据 vacuous tie 过度乐观

0=0 应显示 No data / not evaluated , 不要使用绿色 pass , 避免 accountant 误以为 register 已核对。

CB-AE2E-030 - Knowledge 在 onboarding 后仍为空

Canonical facts 成功 promotion 后 , Knowledge 应显示来源、verified status、version 和最后确认人 ; 不要复制 interview prose。

P3 - Polish and governance

CB-AE2E-031 - 品牌大小写不一致

ClaraBook / clarabook 从单一 brand source 统一。

CB-AE2E-032 - Tax 页面把未来路线图当产品

Beta 未支持就用明确 unavailable + scope + feedback , 不显示内部 build plan。

CB-AE2E-033 - Admin section 对非 Admin 的名称误导

按 capability 重命名为 Firm controls , 或只对 Admin/Owner 显示 ; Bookkeeper 只看到允许的 roster/compliance read。

CB-AE2E-034 - Bank reconciliation empty state 重复

合并重复块 , 给单一下一步 : Add account / Upload statement / Resolve exceptions。

CB-AE2E-035 - Release provenance 不可唯一反查

/build-info 返回 web git SHA、runtime artifact digest、DB migration frontier、classifier/interview/report template versions ; 不要靠 Fly v74 或时间推测源码。

CB-AE2E-036 - Browser E2E 不是 required CI gate

PR required smoke + nightly live-stack ; 至少覆盖本文 Beta Exit Pack , unexpected console/network failure 直接红。

6. 后台与数据层实测结论

检查	当前生产事实	判定
Client status	active	PASS
Canonical identifiers	bank account + 本次补入 SSM/TIN	DB PASS ; 产品 promotion FAIL
General egress consent	0 live	BLOCKED
Typed egress consent	0 live	BLOCKED
Purpose activation	0 live	BLOCKED
Sales lane	本次 ON->OFF ; 最终 OFF , watermark 已记录	GOVERNED DB DOOR PASS ; UI FAIL
Members	1 owner + 1 bookkeeper	PASS
Opening approval proconfig	只有 search_path=clara, pg_temp	P0 FAIL

检查	当前生产事实	判定
reconcile_autopost_rules	DB count=0 ; runtime v74 仍调用	P1 DEPLOY DRIFT
Report templates	0	P1 FAIL
Report template versions	0	P1 FAIL
Client report artifacts	0	EXPECTED GIVEN BLOCKER
Runtime health checks	2/2 passing	MISLEADING : 未覆盖 reconciler error loop

关键结论

- 1. Database walls 大多能挡住非法角色。例如 Bookkeeper 改 threshold 得到 CLR04 , invite replay 也被拒绝。
- 2. UI capability 没有与 DB wall 同步。用户仍看见并能点不属于自己的控制。
- 3. 健康检查太浅。runtime v74 2/2 green , 同时业务 reconciler 每约 2 秒报错。
- 4. 部署版本号不是证据。v72、v73、v74 已 complete , 但 retired caller 仍在生产执行 ; 必须绑定 artifact digest + git SHA。

7. 推荐修复阶段

Stage 0 - 当天 : 冻结不安全 release

- 1. Checkout 临时保持 sandbox-only , 并加入 live-key hard fail。
- 2. Legal owner 完成 DPA/Terms bytes ; 两个独立 receipts。
- 3. 部署 opening serializable ceremony ; 加 production preflight。
- 4. 修 runtime artifact pipeline , 确认 retired caller 真正从 served image 消失。

Exit gate : P0=0 ; runtime 连续 10 分钟无 retired-function log。

Stage 1 - 1-2 天 : 让新 firm/新 client 不需工程师

- 1. OTP CTA + resend。
- 2. DPA signed hydration。
- 3. Firm setup recoverable interview。
- 4. Onboarding typed presenters ; canonical promotion。
- 5. Opening UI 显示完整 gate , 失败不关闭 dialog。

Exit gate : clean signup 到 active client , 全 UI、无 DB bridge。

Stage 2 - 2-4 天 : 补 consent、bank、sales

- 1. Consent Center 的 evidence->grant->activate->revoke。
- 2. Maybank/Alliance 真实去敏 fixtures。

3. Statement ingestion stage diagnostics。
4. Sales activation/status + CLR23 resolution/requeue。
5. Bookkeeper maker-checker policy 由 Founder 明确，代码和 UI 同步。

Exit gate：一张 statement 和一张 invoice 从 document 到 governed journal 完整闭环。

Stage 3 - 2-4 天：Close 与 Reports

1. Close typed state machine、正确 refusal、Restart。
2. 发布默认 management template。
3. Select->run->seal->download。
4. Statutory wording 未 verified 前继续 fail closed。

Exit gate：预置 test FY 解决 blockers 后 close，并产出 deterministic management report。

Stage 4 - 1-3 天：Beta hardening

1. Capability-driven nav/actions。
2. Activity timeline。
3. 200% zoom、keyboard、screen reader、360px authenticated shell。
4. Security headers/CSP、route budgets、required browser E2E、build manifest。

8. Engineer acceptance pack

ID	Scenario	必须留下的证据
ENTRY-01	Signup->OTP->DPA+Terms->sandbox checkout->claim	Auth receipt、2 legal receipts、Stripe test object、firm claim
ENTRY-02	OTP expired->resend	Old rejected、new accepted、no enumeration
OPEN-01	COA->opening items->TB targets->approve	UI success、serializable proof、batch entries、receipt
MEMBER-01	Invite Bookkeeper->accept->replay->remove	Mail、active role、replay refused、session revoked
ROLE-01	Bookkeeper direct owner URL/action	Hidden in DOM；direct call typed 403/CLR04
JOURNAL-01	Maker creates->different checker approves->reverse	Actor separation、immutable audit、net restored
ONB-01	Interview->confirm SSM/TIN/bank/entity/MSIC->commit	Exactly-one canonical rows；tabs rehydrate
CONSENT-01	Evidence->Grant->Activate->Revoke	Block->allow exact purpose->block；3 receipts
DOC-01	Upload unknown/Maybank/Alliance	Fail-closed unknown；correct MBB/ALB、period、account、lines
SALES-01	Ambiguous counterparty->CLR23->resolve->retry	One safe question、no cross-client candidate、one draft
AUTO-01	Runtime leader 10 minutes	No retired caller log；expired rule behavior preserved
CLOSE-01	Blocked->resolve->restart->finalize	Server readiness、serialized close、segregation receipt
RPT-01	Template->run->seal->download	Immutable version、deterministic figures、authorized bytes
SEC-01	Cross-firm IDs on all read/write APIs	No object metadata leakage；deny logged
A11Y-01	200% zoom + keyboard + screen reader	No clipped task；focus return；status announced

ID	Scenario	必须留下的证据
OPS-01	/build-info vs deployment	SHA、digest、migration frontier、runtime/template versions match

9. Beta exit gate

不可用“差不多好了”放行。以下全部为 true 才可称 beta-ready：

- 0 open P0，0 open P1。
- DPA 与 Terms 是 final bytes，分别有 current receipt。
- Stripe 在 startup、deploy、request 三层证明 test mode。
- Clean firm 从 signup 到 active client 完全不需 DB bridge。
- Opening browser approval 在 production serializable ceremony 下通过。
- Bookkeeper role 的可见 UI 与 DB capability 一致；maker-checker policy 有明确验收。
- Canonical SSM/TIN/bank/entity/MSIC 只输入一次并 rehydrate。
- Typed consent 的 Grant/Activate/Revoke 全 UI 可完成。
- Maybank 与 Alliance statement corpus 通过 classify/period/institution/account/lines。
- Runtime 连续 10 分钟无 retired caller error；health 能反映 reconciler failure。
- Sales CLR23 可由用户 resolve/retry，且 idempotent。
- Close 完成一条真实 blocked->resolve->finalize journey。
- 至少一个 approved management-report template 可 run/seal/download。
- Activity 能看见关键 actor/time/action/result。
- Authenticated shell 在 native 200% zoom 可用。
- Required CI 跑
ENTRY/OPEN/MEMBER/ROLE/JOURNAL/ONB/CONSENT/DOC/SALES/AUTO/CLOSE/RPT/SEC/A11Y/OPS。

10. Final professional opinion

ClaraBook 的 strongest layer 是数据库治理思路：typed refusals、idempotency、reversal、one-time invite、角色墙和 immutable report/opening 概念都已经存在。Weakest layer 是“最后一公里”：正常用户看不到治理状态、不能自行完成治理动作、失败后不知道怎么恢复，production artifact 又没有可靠证明自己运行的是哪一份 source。

因此本次结论是 NO-GO for public beta，GO for a closed engineering beta only。Closed engineering beta 必须限制在专用 fixture、Stripe sandbox、人工监控 runtime logs，并明确 Documents/Bank/Sales/Close/Reports 仍不是可独立完成的功能。

附录 A - 完整截图目录（79 张）

截图位于本报告同目录的 [screenshots/](#)。编号即时间顺序：

- 01-12 : Signup、OTP、firm setup、pending、DPA、CLR09、Stripe sandbox、payment success。
- 13-24 : Firm home、Admin、Members、Compliance、Vendor bindings、Settings、Activity、Needs you、Clients empty。
- 25-31 : Client creation、onboarding interview、SST timeout、[object Object]、opening blocker。
- 32-41 : Journals/Documents/Bank surface、CLR11、statement/matching/exceptions/reconciliation/hold。
- 42-50 : Close FYE、FY、gates、CLR41、hold、Clara false-session refusal/fullscreen。
- 51-57 : Tax、Reports snapshot、Registers、Knowledge。
- 58-65 : Opening draft、OBE plug、ties、attestation、full tie、finalize、client active。
- 66-70 : Bank account、journal draft/approve/reverse。
- 71-78 : Bookkeeper invitation、first login、owner-door refusal、clients/journals、自批、invite replay、Members。
- 79 : Authenticated shell 在窄窗/高 zoom 下被 rails 压毁。

附录 B - 关键代码/运行证据索引

- [apps/web/components/entry/signup-dpa-form.tsx](#) - DPA/Terms gate。
- [apps/web/lib/checkout/stripe-session.ts](#) - Stripe mode guard。
- [apps/web/components/opening/OpeningDoorDialog.tsx](#) 及 opening action wrapper - silent close。
- [packages/db/deploy/wave-b-0017-ceremony.sql](#) - opening serializable ceremony。
- [packages/runtime/lib/reconciler.mjs](#)、[packages/runtime/lib/leader.mjs](#) - retired autopost caller 的 current-main removal intent。
- [packages/db/migrations/0118_f_a2_cutover_retirement.sql](#) - DB function retirement。
- [packages/db/migrations/0123_f_a7_gamma_egress.sql](#) - typed consent grant/activate contract。
- [packages/db/migrations/0065_wave_e_epsilon_reporting.sql](#) - report template foundation。
- [apps/web/e2e/README.md](#) - browser E2E 目前不是 required gate。
- Production Fly evidence : machine version 74、2/2 checks passing , 同时 live logs 约每 2 秒 missing-function error。